



FFIEC Information Technology Examination Handbook

Information Security

SEPTEMBER 2016

Contents

INTRODUCTION.....	1
I GOVERNANCE OF THE INFORMATION SECURITY PROGRAM.....	3
I.A Security Culture.....	3
I.B Responsibility and Accountability	3
I.C Resources	5
II INFORMATION SECURITY PROGRAM MANAGEMENT	6
II.A Risk Identification.....	7
II.A.1 Threats	8
II.A.2 Vulnerabilities	8
II.A.3 Supervision of Cybersecurity Risk and Resources for Cybersecurity Preparedness	9
II.B Risk Measurement.....	10
II.C Risk Mitigation	11
II.C.1 Policies, Standards, and Procedures.....	11
II.C.2 Technology Design.....	12
II.C.3 Control Types	12
II.C.4 Control Implementation	13
II.C.5 Inventory and Classification of Assets	14
II.C.6 Mitigating Interconnectivity Risk	14
II.C.7 User Security Controls.....	15
II.C.8 Physical Security	18
II.C.9 Network Controls	19
II.C.10 Change Management Within the IT Environment.....	21
II.C.11 End-of-Life Management	25
II.C.12 Malware Mitigation.....	25
II.C.13 Control of Information	26
II.C.14 Supply Chain	29
II.C.15 Logical Security	30
II.C.16 Customer Remote Access to Financial Services	35
II.C.17 Application Security	38
II.C.18 Database Security	40
II.C.19 Encryption	40
II.C.20 Oversight of Third-Party Service Providers	42

II.C.21	Business Continuity Considerations	43
II.C.22	Log Management.....	44
II.D	Risk Monitoring and Reporting	45
II.D.1	Metrics.....	45
III	SECURITY OPERATIONS.....	46
III.A	Threat Identification and Assessment.....	47
III.B	Threat Monitoring	48
III.C	Incident Identification and Assessment	49
III.D	Incident Response.....	50
IV	INFORMATION SECURITY PROGRAM EFFECTIVENESS	52
IV.A	Assurance and Testing	53
IV.A.1	Key Testing Factors.....	53
IV.A.2	Types of Tests and Evaluations	54
IV.A.3	Independence of Tests and Audits	56
IV.A.4	Assurance Reporting.....	56
	APPENDIX A: EXAMINATION PROCEDURES	57
	APPENDIX B: GLOSSARY	75
	APPENDIX C: LAWS, REGULATIONS, AND GUIDANCE	89

Introduction

This “Information Security” booklet is an integral part of the *Federal Financial Institutions Examination Council (FFIEC)¹ Information Technology Examination Handbook (IT Handbook)* and should be read in conjunction with the other booklets in the *IT Handbook*. This booklet provides guidance to examiners and addresses factors necessary to assess the level of security risks to a financial institution’s² information systems.³ It also helps examiners evaluate the adequacy of the information security program’s integration into overall risk management.⁴

Information security is the process by which a financial institution protects the creation, collection, storage, use, transmission, and disposal of sensitive information, including the protection of hardware and infrastructure used to store and transmit such information. Information security promotes the commonly accepted objectives of confidentiality, integrity, and availability of information and is essential to the overall safety and soundness of an institution. Information security exists to provide protection from malicious and non-malicious actions that increase the risk of adverse effects on earnings, capital, or enterprise value. The potential adverse effects can arise from the following:

- Disclosure of information to unauthorized individuals.
- Unavailability or degradation of services.
- Misappropriation or theft of information or services.
- Modification or destruction of systems or information.
- Records that are not timely, accurate, complete, or consistent.

¹ The FFIEC was established on March 10, 1979, pursuant to Title X of the Financial Institutions Regulatory and Interest Rate Control Act of 1978, Public Law 95-630. The FFIEC is composed of the principals of the following: the Board of Governors of the Federal Reserve System (FRB), the Federal Deposit Insurance Corporation (FDIC), the National Credit Union Administration (NCUA), the Office of the Comptroller of the Currency (OCC), the State Liaison Committee (SLC), and the Consumer Financial Protection Bureau (CFPB).

² The term “financial institution” includes national banks, federal savings associations, state savings associations, state member banks, state nonmember banks, and credit unions. The term is used interchangeably with “institution” in this booklet.

³ Examiners should also use this booklet to evaluate the performance by third-party service providers, including technology service providers, of services on behalf of financial institutions.

⁴ This booklet addresses regulatory expectations regarding the security of all information systems and information maintained by or on behalf of a financial institution, including a financial institution’s own information and that of all of its customers. An institution’s overall information security program must also address the specific information security requirements applicable to “customer information” set forth in the “Interagency Guidelines Establishing Information Security Standards” implementing section 501(b) of the Gramm–Leach–Bliley Act and section 216 of the Fair and Accurate Credit Transactions Act of 2003. See 12 CFR 30, appendix B (OCC); 12 CFR 208, appendix D-2 and 225, appendix F (FRB); 12 CFR 364, appendix B (FDIC); and 12 CFR 748, appendix A (NCUA) (collectively referenced in this booklet as the “Information Security Standards”).

Institutions should maintain effective information security programs commensurate with their operational complexities.⁵ Information security programs should have strong board and senior management support, promote integration of security activities and controls throughout the institution's business processes, and establish clear accountability for carrying out security responsibilities. In addition, because of the frequency and severity of cyber attacks, the institution should place an increasing focus on cybersecurity controls, a key component of information security.

Institutions should also assess and refine their controls on an ongoing basis. The condition of a financial institution's controls, however, is just one indicator of its overall security posture. Other indicators include the ability of the institution's board and management to continually review the institution's security posture and react appropriately in the face of rapidly changing threats, technologies, and business conditions. Information security is far more effective when management does the following:

- Integrates processes, people, and technology to maintain a risk profile that is in accordance with the board's risk appetite.⁶
- Aligns the information security program with the enterprise risk management program and identifies, measures, mitigates, and monitors risk.

Because risk mitigation frequently depends on institution-specific factors, this booklet describes processes and controls that an institution can use to protect information and supporting systems from various threats. Management should be able to identify and characterize the threats, assess the risks, make decisions regarding the implementation of appropriate controls, and provide appropriate monitoring and reporting.

Financial institutions may outsource some or all of their IT-related functions. Although the use of outsourcing may change the location of certain activities from financial institutions to third-party service providers, outsourcing does not change the regulatory expectations for an effective information security program. Examiners should use this booklet when evaluating a financial institution's risk management process, including the duties, obligations, and responsibilities of the third-party service provider regarding information security and the oversight exercised by the financial institution.

⁵ See also Information Security Standards, section II.A, requiring each financial institution to have a comprehensive written information security program, appropriate to its size and complexity, designed to (1) ensure the security and confidentiality of "customer information"; (2) protect against any anticipated threats or hazards to the security or integrity of such information; (3) protect against unauthorized access to or use of such information that could result in a substantial harm or inconvenience to any customer; and (4) ensure the proper disposal of both "customer information" and any "consumer information."

⁶ Risk appetite can be defined as the amount of risk a financial institution is prepared to accept when trying to achieve its objectives.

I Governance of the Information Security Program

Action Summary

Management should promote effective IT governance by doing the following:

- Establishing an information security culture that promotes an effective information security program and the role of all employees in protecting the institution's information and systems.
- Clearly defining and communicating information security responsibilities and accountability throughout the institution.
- Providing adequate resources to effectively support the information security program.

While IT governance is generally addressed in the *IT Handbook's* "Management" booklet, this booklet addresses specific governance topics related to information security, including the following:

- Implementation and promotion of security culture.
- Assignment of responsibilities and accountability.
- Effective funding and use of resources.

I.A Security Culture

An institution's security culture contributes to the effectiveness of the information security program. The information security program is more effective when security processes are deeply embedded in the institution's culture.

The board and management should understand and support information security and provide appropriate resources for developing, implementing, and maintaining the information security program. The result of this understanding and support is a program in which management and employees are committed to integrating the program into the institution's lines of business, support functions, and third-party management program.

The introduction of new business initiatives (such as new service offerings or applications) can reveal the maturity of and degree to which information security is part of the institution's culture. An institution with a stronger security culture generally integrates information security into new initiatives from the outset and throughout the life cycles of services and applications. Another indicator of an effective culture is whether management and employees are held accountable for complying with the institution's information security program.

I.B Responsibility and Accountability

The board, or designated board committee, should be responsible for overseeing the development, implementation, and maintenance of the institution's information security program and holding senior management accountable for its actions. The board should reasonably

understand the business case for information security and the business implications of information security risks; provide management with direction; approve information security plans, policies, and programs; review assessments of the information security program's effectiveness; and, when appropriate, discuss management's recommendations for corrective action. The board should provide management with its expectations and requirements and hold management accountable for central oversight and coordination, assignment of responsibility, and effectiveness of the information security program.

The board, or designated board committee, should approve the institution's written information security program; affirm responsibilities for the development, implementation, and maintenance of the program; and review a report on the overall status of the program at least annually.⁷

Management should provide a report to the board at least annually⁸ that describes the overall status of the program and material matters related to the program, including the following:

- Risk assessment process, including threat identification and assessment.
- Risk management and control decisions, including risk acceptance and avoidance.
- Third-party service provider arrangements.
- Results of testing.
- Security breaches or violations of law or regulation and management's responses to such incidents.
- Recommendations for updates to the information security program.

When providing reports on information security, management should include the results of management assessments and reviews; internal and external audit activity related to information security; third-party reviews of the information security program and information security measures; and other internal or external reviews designed to assess the adequacy of the information security program, processes, policies, and controls.

Management also should do the following:

- Implement the board-approved information security program.
- Establish appropriate policies, standards, and procedures to support the information security program.
- Participate in assessing the effect of security threats or incidents on the institution and its lines of business and processes.
- Delineate clear lines of responsibility and communicate accountability for information security.

⁷ See also Information Security Standards, section III.A, requiring the board of directors or an appropriate committee of the board of each financial institution to approve the institution's written information security program, and oversee the development, implementation, and maintenance of the program, including assigning specific responsibility for its implementation and reviewing management reports.

⁸ See also Information Security Standards, section III.F, requiring each financial institution to report to its board or an appropriate committee of the board at least annually. The report should include a description of the institution's compliance with the Information Security Standards and discuss material matters related to its information security program.

- Adhere to board-approved risk thresholds relating to information security threats or incidents, including those relating to cybersecurity.
- Oversee risk mitigation activities that support the information security program.
- Implement a risk acceptance process that identifies the risk and when, how, to what extent, and who in management has accepted the risk associated with identified vulnerabilities.
- Establish segregation of duties.
- Coordinate information and physical security.
- Integrate security controls throughout the institution.
- Require that data with similar criticality and sensitivity be protected consistently throughout the institution.
- Establish and monitor the information security responsibilities of third parties, as further described in the “Oversight of Third-Party Service Providers” section of this booklet.
- Maintain job descriptions or employment contracts that include specific information security responsibilities.
- Provide information security and awareness training and ongoing security-related communications to employees, and ensure employees complete such training annually.

Management should designate at least one information security officer responsible and accountable for implementing and monitoring the information security program. Information security management responsibilities may be distributed across various lines of business depending on where the risk decisions are made and the institution’s size, complexity, culture, nature of operations, or other factors.

Information security officers should report directly to the board or senior management and have sufficient authority, stature within the organization, knowledge, background, training, and independence to perform their assigned tasks. To ensure appropriate segregation of duties, the information security officers should be independent of the IT operations staff and should not report to IT operations management. Information security officers should be responsible for responding to security events by ordering emergency actions to protect the institution and its customers from imminent loss of information; managing the negative effects on the confidentiality, integrity, availability, or value of information; and minimizing the disruption or degradation of critical services.

Internal auditors should implement a risk-based audit program to ensure management maintains and the board oversees an effective information security program. Additionally, management should issue appropriate reports to the board. Refer to the *IT Handbook*’s “Audit” booklet.

I.C Resources

Funding, along with technical and managerial talent, also contributes to the effectiveness of the information security program. Management should provide, and the board should oversee, adequate funding to develop, implement, and maintain a successful information security program. The program should be staffed by sufficient personnel who have skills that are aligned with the institution’s technical and managerial needs and commensurate with its size, complexity, and risk profile. Knowledge of technology standards, practices, and risk methodologies is particularly important to the success of the information security program.

When third-party service providers supplement an institution's technical and managerial capabilities, management oversight should be commensurate with the sensitivity and criticality of the information and business processes supported by the third-party service provider. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for more information.

II Information Security Program Management

Action Summary

Management should develop and implement an information security program that does the following:

- Supports the institution's IT risk management (ITRM) process by identifying threats, measuring risk, defining information security requirements, and implementing controls.
- Integrates with lines of business and support functions in which risk decisions are made.
- Integrates third-party service provider activities with the information security program.

The institution should have a robust and effective information security program that supports the institution's ITRM process.⁹ An effective information security program includes the following:

- Risk identification
- Risk measurement
- Risk mitigation
- Risk monitoring and reporting

Refer to the *IT Handbook's* "Management" booklet for more information. A comprehensive information security program should incorporate cybersecurity elements, and management should identify, measure, mitigate, monitor, and report cybersecurity-related risks in accordance with the information security program and the ITRM process. In addition, to determine the overall effectiveness of the information security program, management should have comprehensive assurance and testing processes.

Management should integrate the information security program with the institution's lines of business and support functions. An integrated program provides management the ability to assess the likelihood and potential damage to the institution from an incident, identify the root cause(s) of the incident, and implement controls to address identified issues.

Institutions that outsource technology, line of business activities, and support functions should ensure integration of these activities with the information security program through an effective

⁹ See also Information Security Standards, section III.B, requiring each financial institution to assess risk including through the identification of reasonably foreseeable internal and external threats that could result in unauthorized disclosure, misuse, alteration, or destruction of "customer information" or "customer information systems," and section III.C, requiring each financial institution to manage and control its risks by (1) designing an information security program to control risks it identifies commensurate with the sensitivity of the information and the complexity and scope of the institution's activities, and (2) adopting an enumerated list of controls, as appropriate.

third-party service provider management program.¹⁰ Effective integration of these programs is evident when the institution creates and enforces expectations that align with the internal information security program in such a way that the combined activities of the institution and its third-party service providers result in an acceptable level of risk. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for more information.

II.A Risk Identification

Action Summary

Management should develop and implement a process to identify risk.

Risk is the potential that events, expected or unanticipated, may adversely affect the institution's earnings, capital, or reputation. Risk is considered in terms of categories, one of which is operational risk. Operational risk is the risk of failure or loss resulting from inadequate or failed processes, people, or systems. Internal and external events can affect operational risk. Internal events include human errors, misconduct, and insider attacks. External events affecting IT and the institution's ability to meet its operating objectives include natural disasters, cyber attacks, changes in market conditions, new competitors, new technologies, litigation, and new laws or regulations. These events pose risks and opportunities, and the institution should factor them into the risk identification process.

To be effective, an information security program should have documented processes to identify threats and vulnerabilities continuously. Risk identification should produce groupings of threats, including significant cybersecurity threats. A taxonomy¹¹ for categorizing threats, sources, and vulnerabilities can help support the risk identification process. Management should perform these risk identification activities to determine the institution's information security risk profile, including cybersecurity risk.

¹⁰ See also Information Security Standards, section III.D, requiring each financial institution to oversee service provider arrangements by (1) exercising appropriate due diligence in selecting its service providers; (2) requiring its service providers by contract to implement appropriate measures designed to ensure the security and confidentiality of the institution's "customer information"; and (3) where indicated by the institution's risk assessment, monitoring its service providers to confirm that the service providers have satisfied their contractual obligations, including by reviewing audits, summaries of test results, or other equivalent evaluations of its service providers.

¹¹ A taxonomy is a method for classifying items into ordered categories. Institutions use taxonomies to find relevant information from a large collection of data and to better detect or understand the patterns and trends.